

Table of Contents

Cisco Secure Workload — HIPAA Security Rule (2025 NPRM) Alignment

Reference Design | Proposed Rule — **Not Final Law**

Version: 1.0

Basis of mapping: HHS Notice of Proposed Rulemaking (NPRM) updates to the HIPAA Security Rule (published **January 2025** — confirm effective/final rule in **Federal Register** before relying on this document for legal compliance).

Use Case: Fresh install, hybrid environment (on-prem + cloud)

Critical caveat: This reference design interprets a **proposed** regulation. The **final rule may differ**. Maintain parallel compliance with the **current** Security Rule until amendments are effective.

Reader's Guide

Who this is for. Covered entities and business associates planning for **proposed** HIPAA Security Rule modernisation, security architects who must **pre-position** technical controls (especially **mandatory network segmentation**), and compliance officers who need a **crosswalk** from **today's rule** to the **NPRM**.

Questions this reference design helps you answer:

- *If **network segmentation** becomes **required** (no longer merely addressable), what **technical proof** can I operate **continuously**? (§164.312(a)(2)(vi) — **headline CSW mapping**)*
- *How do strengthened **access controls** and **technology asset inventory** change what I must **instrument**? (§164.312(a)(1), §164.308(a)(1)(ii)(A))*
- *How does the NPRM's emphasis on **inventory** + **network map** for **risk analysis** translate into **CSW ADM** and exports? (§164.308(a)(1)(ii)(B))*
- *What **vulnerability management** evidence does CSW produce for the **new** NPRM expectation? (§164.308(a)(2))*
- *If **audit log retention** extends to **24 months**, how do I **export** CSW telemetry to **durable storage** / **SIEM**? (§164.312(b))*
- *If **encryption** for ePHI **at rest and in transit** moves to **required**, how does CSW support **plaintext detection and blocking** while I remediate apps? (Map to **final NPRM** section numbers — today's rule places **encryption in transit** primarily under §164.312(e) and related provisions; NPRM may **renumber**.)*

- For **72-hour HHS notification**, what **forensic timelines** can CSW contribute? (§164.308(a)(6))
- For **annual compliance assessment**, what **continuous** artefacts supplement point-in-time audits? (§164.306(e))

What you'll need. Your organisation's **current HIPAA** compliance baseline (see the **existing CSW HIPAA reference design** below), ePHI data-flow documentation, SIEM / log retention architecture, and legal review of the **final** rule when published.

Where to start. Section 1 (**NPRM vs current rule** quick reference); sections 2–4 for deployment; sections 5–7 for policy; section 8 for **control mapping**; section 9 **boundaries**; section 10 **evidence** aligned to **24-month** thinking.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Supports proposed mandatory segmentation evidence (§164.312(a)(2)(vi))
- Asset inventory + 72-hour breach timeline inputs from flow/process search
- Continuous logging architecture vs. point-in-time log samples

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

The **2025 NPRM** proposes substantial updates to the HIPAA Security Rule to reflect modern threats, cloud adoption, and accountability expectations. **Cisco Secure Workload (CSW)** remains a **technical control and evidence system** for workload visibility, **microsegmentation**, vulnerability context with **EPSS**, and forensic telemetry. It does **not** satisfy administrative, physical, or legal obligations by itself.

1.1 “Current rule” vs. NPRM (operational implications)

Use this table with your compliance and privacy counsel; citations follow **proposed** structure as commonly discussed in the NPRM — **verify against the official FR text**.

Theme	Current Security Rule posture (typical)	NPRM direction (why it matters for CSW)
Network segmentation	Often treated as addressable ; organisations document compensating controls	Mandatory network segmentation between ePHI and non-ePHI — microsegmentation becomes a primary

Theme	Current Security Rule posture (typical)	NPRM direction (why it matters for CSW)
		technical anchor
Technology asset inventory	Implicit in risk analysis; variable formality	Explicit inventory requirement — CSW discovery + software inventory maps cleanly
Risk analysis	Required; depth varies	Enhanced — expects inventory + network map — ADM + flow topology
Vulnerability management	Addressed under risk management / §164.308(a)(8) in practice	Proposed explicit vulnerability management — CVE + EPSS + reachability
Audit controls / retention	Retention not specified in HIPAA to match 24 months uniformly	Proposed 24-month log retention — export architecture to SIEM/object store
Encryption	Some encryption elements addressable in current rule	Proposed required ePHI encryption at rest and in transit — CSW assists with plaintext detection/blocking; encryption implementation remains with apps/storage
Incident notification	Breach notification rules under separate provisions	NPRM discourse on timely HHS notification (e.g. 72-hour themes in proposals) — forensic evidence speed
Annual compliance assessment	Evaluation under §164.308(a)(8)	Proposed annual compliance assessment — continuous monitoring evidence from CSW

1.2 Relationship to the existing HIPAA reference design

For controls that **do not change** materially in the NPRM, the detailed phased guidance in the **current-rule reference design** remains authoritative for CSW deployment patterns:

Primary cross-reference: ../HIPAA/CSW-HIPAA-Reference-Design.md

NPRM topic	CSW focus this document	Deeper procedural detail
ePHI zone architecture, PHI labelling, ADM for clinical apps	§1–§5 overview + segmentation headline	HIPAA reference design §4–§5
Policy workspace patterns (simulation → enforcement)	§6–§7	HIPAA reference design §6
Vulnerability management	§5–§6, §8	HIPAA reference design §8
Monitoring & forensic exports	§7–§10	HIPAA reference design §9–§10

Practice: Treat the **HIPAA reference design** as the **implementation backbone**; treat **this NPRM reference design** as the **delta tracker + evidence adjustments** (especially **segmentation, 24-month logs, inventory, vuln programme**).

2. Pre-Deployment Checklist

Before expanding CSW for **NPRM readiness**:

- ☐ **Legal / compliance** confirms which **proposed** provisions your roadmap assumes (prioritise **segmentation** and **logging retention** architecture early)
 - ☐ CSW cluster reachable; sensors planned for **all** ePHI-adjacent tiers (not only “Crown Jewel” servers)
 - ☐ **SIEM / log lake** capacity scoping for **≥24-month** CSW-derived audit metadata (see §10)
 - ☐ Identity integration path chosen for **identity-aware enforcement (§164.312(a)(1) alignment)**
 - ☐ **Plaintext protocol inventory** workshop scheduled (TLS migration backlog)
 - ☐ Stakeholders: CISO, HIPAA Security Officer, Infrastructure, **Privacy Officer** (if data-use discussions arise)
-

3. Phase 1 — Sensor deployment (Days 1–5)

Follow the **HIPAA reference design** steps verbatim for install patterns; repeat here for continuity.

3.1 On-premises

```
# Linux (RHEL/CentOS/Ubuntu family)
rpm -ivh tet-sensor-<version>.rpm      # RHEL/CentOS
dpkg -i tet-sensor-<version>.deb       # Ubuntu/Debian
```

```
systemctl status csw-agent || systemctl status tet-sensor
```

3.2 Cloud connectors

CSW UI → Platform → External Orchestrators

→ AWS / Azure / GCP

→ Enable inventory + flow ingestion appropriate to your license

3.3 NPRM-oriented sensor settings

- **Monitoring-only** initially on newly onboarded ePHI-adjacent tiers (**avoid disruption** during risk analysis refresh)
 - Enable artefacts needed for **technology asset inventory**: instance IDs, agent IDs, **software packages**
 - Tags: `compliance:hipaa`, `data:ephi`, `nprm-scope:2025-planning` (or your internal programme name)
-

4. Phase 2 — Scope & technology asset inventory (Days 6–12)

4.1 Inventory as a **first-class** NPRM deliverable (§164.308(a)(1)(ii)(A))

The NPRM elevates **technology asset inventory** from implied to **explicit**. CSW contributions:

Inventory element	CSW source	Evidence tip
Workload identity	Agent inventory / cloud connector	Export weekly during remediation projects
Software packages & versions	Software inventory module	Join to CMDB via <code>external_id</code> / <code>hostname</code>
Network exposure	Listen sockets + ADM edges	Attach to risk register entries

4.2 Segmentation-oriented scope design (§164.312(a)(2)(vi))

Rebuild (or validate) scopes assuming **ePHI vs non-ePHI** is **mandatory** in enforcement, not “best effort”:

PHI-Zone (enforce deny-by-default)

Non-PHI-Enterprise

DMZ / Internet Edge

BA-Partner-Connectivity

Admin-Jump-Path

Delta from current HIPAA reference design: same zone labels — **stronger expectation** that **deny-by-default between PHI and non-PHI** is **documented, enforced, and drift-monitored**, not optional.

5. Phase 3 — Visibility, network map & risk analysis refresh (Days 13–30)

5.1 Risk analysis support (§164.308(a)(1)(ii)(B))

Proposed rule direction: risk analysis should **incorporate** a **technology asset inventory** and **network map**. CSW **ADM** supplies an **observed** map:

CSW UI → Investigate → Application Dependency Mapping
→ Workspace: "HIPAA-NPRM-RiskAnalysis-2025"
→ Scope: organisation root or PHI-Zone + dependencies
→ Window: minimum 2–4 weeks
→ Process + user context enabled

Deliverable: ADM export + narrative tying each **ePHI system class** to observed **ingress/egress** partners (including **BAs** by FQDN/IP).

5.2 Vulnerability management programme (§164.308(a)(2) — *proposed*)

Operationalise **continuous** assessment:

CSW UI → Investigate → Vulnerability Report
→ Scope: PHI-Zone + admins paths
→ Prioritise: CVSS + EPSS + internet/exposed reachability

Map outputs into your **enterprise vuln SLAs**; CSW answers: **which ePHI-adjacent workloads are both vulnerable and reachable**.

6. Phase 4 — Policy design (microsegmentation — **headline**)

6.1 §164.312(a)(2)(vi) **Network segmentation** — deny-by-default between ePHI and non-ePHI

CSW mapping (headline): Host-based **microsegmentation** provides **default-deny** workload enforcement between **ePHI** and **non-ePHI** segments, **independent of** coarse subnet ACLs—closing gaps when **VPC/VNet** posture drifts or **east-west** paths bypass perimeter controls.

Example policy themes (conceptual):

DENY: Non-PHI-Enterprise → PHI-Zone (default deny; allowlist jump + monitored admin only)
DENY: PHI-Zone → Internet (except approved egress via secured proxy / known APIs)
ALLOW: Clinical-Workstations → EHR-Frontends (tcp/443)
ALLOW: EHR-App → EHR-DB (application-appropriate ports – prefer encrypted protocols)

6.2 §164.312(a)(1) Access control — identity-aware enforcement

Where CSW integrates directory / workload identity:

- Restrict **which identities** / **device classes** may initiate flows **into** PHI-Zone
- Tie **break-glass** and **emergency access** subnets to **time-bound** allow rules with **alerting**

(See [HIPAA reference design §6](#) for concrete allowlist templates.)

6.3 Encryption (at rest & in transit) — plaintext visibility & blocking

Citation note: Under the **current** Security Rule, **§164.312(d)** is *Person or entity authentication*; **encryption in transit** is addressed under **§164.312(e)**, and cryptographic controls also appear elsewhere (e.g. **§164.312(a)(2)(iv)**). The **NPRM** may consolidate or renumber — **replace headings below with final regulatory text** when published.

CSW **does not encrypt data at rest**; it **detects and can block** risky **cleartext transit** paths to drive remediation:

ALERT → DENY (after app owner sign-off):

PHI-Zone → Any on tcp/80, tcp/389, legacy unencrypted database ports where TLS is mandated

Coordinate with **database TLS**, **storage encryption (CMK/TDE)**, and **application crypto** for full **at rest + in transit** compliance.

7. Phase 5 — Enforcement, incidents & continuous assurance

7.1 Enforcement stages

Stage	Objective
Simulation	Prove no clinical breakage before mandatory segmentation stance hardens
Phased enforce	Default deny between PHI/non-PHI first; refine intra-PHI least privilege second
Steady state	Continuous policy review aligned to annual assessment cadence

7.2 §164.308(a)(6) Security incident — 72-hour notification narrative

For **rapid timelines** (per **proposed** emphasis):

CSW UI → Investigate → Flow Search

→ Narrow to compromise window + affected workload

CSW UI → Investigate → Process Search
→ Parent/child chain + hash novelty

Export **immutable** bundles (hash the export file in your IR ticket).

7.3 §164.306(e) Annual compliance assessment (*proposed*)

Maintain **continuous** artefacts:

- Monthly: inventory delta report
 - Quarterly: policy workspace review + ADM refresh
 - Annual: formal assessment package assembling the above + **management attestation**
-

8. Control-by-control mapping (NPRM / Security Rule — proposed)

Legend: Items marked **NPRM Δ** indicate a **material change from typical current-rule implementation** per proposal. **Final text may differ.**

Provision (proposed / discussed)	Requirement intent (summary)	CSW capability	Evidence produced
§164.312(a)(2) (vi) Network segmentation — NPRM Δ mandatory	Segment ePHI from non-ePHI; limit lateral movement	Deny-by-default microsegmentati on between PHI- Zone and others; ADM-backed rules	Policy export; enforcement hit logs; ADM diagram; change history
§164.312(a)(1) Access control — strengthened	Ensure only authorised users/processes access	Identity-aware segmentation; process-level visibility; scoped allowlists	Identity-scoped policy; flow logs with process/user context
§164.308(a)(1)(ii) (A) Technology asset inventory — NPRM emphasis	Maintain accurate tech asset inventory	Automatic workload discovery; software inventory	Scheduled CSV/JSON exports; CMDB reconciliation
§164.308(a)(1)(ii) (B) Risk analysis — network map / inventory	Risk analysis uses inventory & network map	ADM + flow topology exports	ADM workspace + methodology memo
§164.308(a)(2) Vulnerability management — new (proposed)	Active vuln identification & mitigation tracking	CVE awareness, EPSS, exposure/reachab ility	Trended vuln backlog; “critical exposed” views

Provision (proposed / discussed)	Requirement intent (summary)	CSW capability	Evidence produced
§164.312(b) Audit controls — 24-month retention (proposed)	Record & examine ePHI access; retain logs	Flow + process telemetry exported to SIEM/storage meeting retention	SIEM retention proofs; sample queries; export manifests
Encryption / authentication (verify final NPRM §) — <i>today:</i> §164.312(e) transit; §164.312(d) authentication; NPRM may change	Encryption of ePHI at rest & in transit — required (proposed)	Plaintext detection/blockin g ; path hardening telemetry	Protocol reports; pre/post remediation flows
§164.308(a)(6) Security incident procedures	Timely response & notification (e.g. 72-hour HHS themes in proposal)	Forensic flow/process recon	IR export bundles; timeline
§164.306(e) Annual compliance assessment (proposed)	Periodic effectiveness review	Continuous monitoring dashboards + quarterly exports	Assessment workbook appendices

9. Boundaries — what CSW does **not** cover

- **Legal interpretation** of the NPRM or **final rule** — requires **counsel**.
 - **Encryption key management & crypto implementation** — CSW flags **plaintext** and **enforces paths**; HSM/KMS/TDE are separate.
 - **HIPAA Privacy Rule** operational workflows (e.g. patient rights) — not CSW scope.
 - **BAA negotiation & vendor risk scoring** — contractual; CSW shows **technical egress/ingress facts**.
 - **Complete audit log retention in CSW alone** — for **24-month** programmes, plan **SIEM/archive**; verify **integrity** and **access controls** on archives.
 - **Malware prevention as a sole control** — pair with **EDR**; CSW adds **segmentation** and **process intelligence**.
-

10. Audit preparation & 24-month evidence export architecture

10.1 Why architecture matters for §164.312(b)

If **24-month retention** becomes required, **interactive UI lookups** alone are insufficient. Design **forward** to **centralised storage**:

Layer	Recommendation
Real-time	Stream alerts / enforcement / metadata-rich flows to SIEM
Batch	Nightly exports to object storage (versioned bucket)
Integrity	Object versioning / legal hold ; hash manifests in GRC tool

10.2 Bash automation sketch (customer-specific endpoints)

```
#!/usr/bin/env bash
set -euo pipefail
TS="$(date +%Y%m%d)"
EVIDENCE_ROOT="/secure/hipaa-nprm-evidence/${TS}"
mkdir -p "${EVIDENCE_ROOT}"

# Pseudocode – replace with CSW-supported API/CLI for your release:
# python3 scripts/csw_export_flows.py --scope PHI-Zone --start -P30D --out "${EVIDENCE_ROOT}/flows.jsonl"
# python3 scripts/csw_export_inventory.py --scope PHI-Zone --out "${EVIDENCE_ROOT}/inventory.json"
# sha256sum "${EVIDENCE_ROOT}/*" > "${EVIDENCE_ROOT}/MANIFEST.sha256"
```

10.3 Quarterly evidence pack (suggested)

Item	Source	NPRM relevance
Segmentation policy PDF/JSON	CSW Defend	§164.312(a)(2)(vi)
ADM export	CSW Investigate	§164.308(a)(1)(ii)(B)
Inventory	CSW Inventory	§164.308(a)(1)(ii)(A)
Critical CVE + EPSS list	CSW Vulnerabilities	§164.308(a)(2)
Plaintext flow exceptions	Flow search	§164.312(e) <i>today</i> / NPRM encryption — verify final
SIEM retention attestation	GRC	§164.312(b)

10.4 Current rule evidence cadence

Continue **existing** quarterly practices from [../HIPAA/CSW-HIPAA-Reference-Design.md §10](#) until the NPRM is **final** and **effective**; **add** the artefacts above where the **proposed** rule creates **new auditable expectations**.

11. Common pitfalls (NPRM-oriented)

Pitfall	Mitigation
Treating NPRM citations as final law	Track Federal Register ; update mappings after final rule
Segmentation on paper only	Move from simulation to enforce with documented CAB approvals
SIEM costs surprise at 24 months	Model data volume early; filter high-value events
Assuming TLS by port	Inspect actual protocol & termination; east-west matters
Cloud blind spots	Fix connector IAM; include ephemeral workloads

Related frameworks

- **Current HIPAA Security Rule (CSW)**: [../HIPAA/CSW-HIPAA-Reference-Design.md](#)
 - [HITRUST CSF](#) — common healthcare vehicle **mapped to HIPAA**
 - [NIST SP 800-53](#) — control depth for **hybrid** programmes
 - [NIST SP 800-207](#) — zero-trust patterns under **segmentation**
-

Appendix A Conceptual **PHI / non-PHI** deny-by-default fragment

workspace: [HIPAA-NPRM-PHI-DefaultDeny](#)

scope: [PHI-Zone](#)

notes: "Align to final rule text; tune ports to approved architectures."

rulesets:

- name: [block-nonphi-default-inbound](#)
action: [deny](#)
source_scope: [Non-PHI-Enterprise](#)
destination_scope: [PHI-Zone](#)
services: [any](#)
exceptions:
 - [allow_jump_host_admin_paths_only](#)
- name: [alert-cleartext-http-from-phi](#)

action: alert
source_scope: PHI-Zone
destination_scope: any
services: [tcp/80]

Appendix B NPRM Δ one-page brief (for executives)

#	Topic	Why it matters	CSW action
1	Mandatory network segmentation	Reduces blast radius	Enforce PHI-Zone default deny
2	Technology asset inventory	You cannot protect unknown assets	Exports + CMDB sync
3	Vulnerability management	Continuous vs annual checkbox	EPSS + reachability
4	24-month logs	Proving access examinations	SIEM + object store
5	Encryption required	Less “addressable” flexibility	Plaintext detection + app/crypto projects
6	Annual assessment	Prove ongoing effectiveness	Quarterly CSW artefacts bundle

*Document prepared for Cisco healthcare engagements. **Not legal advice.** Update all citations and control interpretations when HHS publishes the **final** Security Rule amendments.*